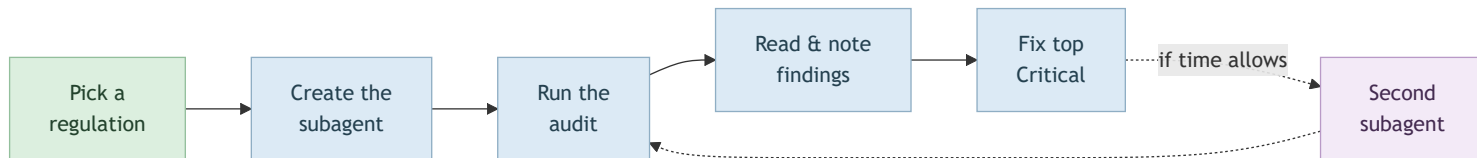


Audit an Earlier Project for Compliance

Pick a regulation · build the subagent · run it · read the findings · fix the worst one

Sprint 4 · budget $\approx$ 30–45 minutes

The Arc



The subagent is read-only. It reports; you decide what to change.

Choose the Regulation That Fits Your App

Access: Claude Code open in one of your earlier projects. Any app from an earlier sprint works. Any tier of Claude Code works.

GDPR

The app collects **personal data** — logins, profiles, anything tied to a real person.

An app with user accounts suits this audit.

EU AI Act

The app has an **AI feature** — a chatbot, AI-generated content.

An app with an AI feature suits this audit.

If the app has **both** — pick whichever interests you more.

Part 1 · Create Your Compliance Subagent

Access: the earlier project, open in Claude Code. · GDPR path.

Create the matching subagent file in `.claude/agents/` by pasting the definition from the audit section. Add the file yourself, or ask the agent to do it.

For the GDPR audit, for example:

```
Create a read-only compliance subagent in .claude/agents/ called
gdpr-compliance. It should check this app against GDPR: whether there is a clear
reason to hold each piece of personal data, whether users can get a copy of
their data and have it deleted, whether consent is handled properly, and whether
the privacy policy matches what the app actually collects. It must never change
anything, only report back a prioritised findings list, and end with a note that
this is a first-pass signal, not legal advice.
```

Two non-negotiables in the definition: it **never changes anything**, and it ends with the note that this is a **first-pass signal, not legal advice**.

Part 1 · The EU AI Act Variant

Same step, other path — use the definition from the audit section. The prompt below mirrors the GDPR one and is **not** quoted from the lab.

```
Create a read-only compliance subagent in .claude/agents/ called
eu-ai-act-compliance. It should check this app against the EU AI Act: whether
users are told clearly when they are interacting with an AI, whether
AI-generated content is labelled as such, which risk category the AI feature
falls into, whether a person can review or override what the AI decides, and
whether there is any record of what the AI was asked and what it produced. It
must never change anything, only report back a prioritised findings list, and
end with a note that this is a first-pass signal, not legal advice.
```

Everything downstream is identical — only the subagent name changes in the Step 1 prompt.

Part 2 · Run the Audit — Steps 1–2

Access: same project, with the subagent file now in `.claude/agents/` .

Step 1 — Run the subagent. Point it at the project and read what comes back:

```
Run the gdpr-compliance subagent on this app and give me the findings report,  
grouped as Critical, Warning, and Suggestion.
```

Step 2 — Read and note the findings. Skim the report and note what it flagged.

Critical items are the ones that would stop you shipping to real users.

Part 2 · Run the Audit — Steps 3–4

Access: same project, findings report in hand.

Step 3 — Fix the top Critical finding (if there is one). Pick the most serious finding and describe the fix you want in **plain language**, letting the agent make the change.

For example:

```
The audit flagged that users have no way to delete their account and data.  
Add a "Delete my account" option for logged-in users that really removes the  
user and everything tied to them.
```

Step 4 — If time allows: build the second subagent too. Create the other subagent from its definition in the audit section, run it on the same project, and read that report as well.

Done When

- ☐ You picked the regulation that fits your app
- ☐ A read-only subagent exists in `.claude/agents/`
- ☐ You have a findings report grouped Critical / Warning / Suggestion
- ☐ You noted what it flagged, and which items would block shipping
- ☐ The top Critical finding is fixed
- ☐ (optional) The second subagent ran on the same project

A first-pass signal, not legal advice.